

PRE-CLASS READING 3 OF 5

Process or product — the two Western frameworks, and why one of them just moved its own deadline

NIST AI Risk Management Framework 1.0 (NIST AI 100-1, January 2023) with its Generative AI Profile (NIST AI 600-1, July 2024) — voluntary, American, and organised around a process. The EU Artificial Intelligence Act, Regulation (EU) 2024/1689 — binding, European, and organised around a product. Both are free and public. They are paired here because they are the two most-cited AI governance instruments in the world and they are not the same kind of thing at all, and because one of them amended its own timetable six weeks before you read this.

ASSIGNED READING

For **NIST**: read the AI RMF 1.0 **Executive Summary and Part 2 (the Core)** — the four functions and what each asks of you (≈ 25 min). Skip the Playbook; it runs to hundreds of suggested actions and is a reference, not a reading. Then skim the **twelve risk names** in the Generative AI Profile — the names alone, not the actions (≈ 5 min). For the **EU AI Act**: do not read the Regulation. It runs to 144 pages of Official Journal text — 180 recitals, 113 articles and 13 annexes. Read the Commission's own **AI Act overview page** and the **risk-tier summary** (≈ 15 min), and if you read one piece of the legal text, read **Article 5** (the prohibitions) because it is short and concrete.

» sources ~45 min • this summary + reasoning notes ~24 min

⚠ **Note on currency** — read this before anything else, because most material in circulation is now wrong. On 27 July 2026 the **Digital Omnibus on AI**, Regulation (EU) 2026/1744, entered into force and amended the AI Act's application timetable. **Prohibitions and general-purpose AI obligations are unchanged and already apply.** But the **high-risk regime** — the Act's actual centre of gravity — has been postponed: **Annex III standalone high-risk systems move from 2 August 2026 to 2 December 2027, and Annex I embedded high-risk systems from 2 August 2027 to 2 August 2028.** Any deck, article, training course or vendor claim stating that high-risk obligations apply from August 2026 is out of date, and a great many do. On the American side: **Executive Order 14110 was revoked on 20 January 2025** (by EO 14148), and **EO 14179, "Removing Barriers to American Leadership in AI", followed on 23 January 2025, the AI Safety Institute was renamed the Center for AI Standards and Innovation (CAISI) on 3 June 2025**, and the July 2025 *America's AI Action Plan* recommended revising the AI RMF itself. **We could not verify that a revised AI RMF 2.0 has been published — treat 1.0 as current and the revision as pending.**

KEY TAKEAWAY

These two documents are answering different questions, and almost every confused AI-governance conversation comes from treating them as competing answers to one question. NIST asks: *did you run a defensible process?* It gives you four functions — **Govern, Map, Measure, Manage** — nineteen categories and seventy-two subcategories of things a mature organisation does, and it has **no legal force whatsoever**. Nothing in it is required of anyone. It becomes binding only where a contract, a procurement term or a sectoral regulator pulls it in, which happens constantly, which is why it matters. The EU asks: *is this product safe to place on the market?* It sorts AI systems into four tiers by **application**, forbids the top tier outright, and requires the second tier to pass a conformity assessment before it can be sold — a regime borrowed wholesale from product-safety law, the same machinery that governs medical devices and machinery. It is binding on anyone placing a system on the EU market wherever they are, and the fines reach **€35 million or 7% of worldwide annual turnover**. **The single sentence to carry into class: NIST regulates the organisation, the EU regulates the artefact.** And the second sentence, which is newer and more surprising: **the binding one just blinked.**

WHY IT MATTERS FOR THIS COURSE

Capsule 2 walks five regulatory regimes and, because the session is over-subscribed, walks the two in this brief quickly — they become a named slide while the Asia-Pacific frameworks in Reading 4 get the class time, since that is where this cohort will work. **That makes this brief the primary treatment of NIST and the EU, not a summary of one.** It also does something the slides cannot: it gives you the *shape* of the two dominant regulatory philosophies, and every other AI law in the world is a variation on one of them or a deliberate rejection of both. A2 asks for a responsible-deployment guardrail checklist — and be precise about which artefact NIST helps with, because it is not the obvious one. **D3(b) is ten executable test cases**, each naming the wrong behaviour it exists to catch; a test case is not a governance control, and the four functions are the wrong shape for it. Where they ARE the most defensible skeleton available, and free, is **report section 6 and the trade-off argument** — the place where you say what you would not deploy, and why. And when a stakeholder asks whether your project is "compliant", this brief is what lets you answer the only useful version of that question: **compliant with what, and binding on whom?**

Feeds Class 6: C2-A (the regulatory landscape — this brief carries the EU/US depth the slide will not have time for) • A2 (NIST's four functions as the skeleton for report section 6 — NOT for D3(b)'s ten test cases) • the end-of-course project (trade-off analysis under constraints).

MAIN POINTS

NIST AI RMF 1.0 — four functions, and the one that does the work

Published **January 2023** as **NIST AI 100-1**, developed through open consultation at Congress's direction. Its Core is four functions, **19 categories and 72 subcategories** in total. The functions are not a sequence; they run continuously and interact.

- **GOVERN — the cross-cutting one, and the one organisations skip.** Policies, accountability structures, roles, culture, workforce diversity, third-party and supply-chain risk. It is listed first for a reason: the other three describe activities, and Govern describes **who is responsible for making them happen and who is accountable when they do not**. In practice this is the function that separates an organisation with AI governance from one with an AI governance document.
- **MAP — establish context and frame risk.** What is this system for, who is affected, what are the intended and unintended uses, what are the interdependencies. The output of Map is not a control; it is a decision about whether the risk is even worth taking, and NIST is explicit that “do not build it” is a legitimate result.
- **MEASURE — analyse, assess, benchmark, monitor.** Quantitative and qualitative. This is where your Week-3 eval harness and Week-6 observability live. NIST is unusually candid here that many trustworthiness characteristics have **no agreed metric**, and says so rather than pretending otherwise.
- **MANAGE — allocate resources to the risks you mapped and measured.** Prioritise, respond, recover, communicate, and — the part that gets skipped — plan for and document **incident response and decommissioning**. The Manage function is where “what triggers a rollback and who may pull it” belongs.

And seven characteristics of trustworthy AI, which run across all four functions: **Valid and Reliable · Safe · Secure and Resilient · Accountable and Transparent · Explainable and Interpretable · Privacy-Enhanced · Fair – with Harmful Bias Managed**. Read the first one carefully — NIST puts *Valid and Reliable* first and calls it a necessary condition for the rest, which is a quietly strong claim: **a system that does not work cannot be made trustworthy by governance**. That is worth remembering the next time a governance programme is proposed as the answer to a model that is not accurate enough.

The Generative AI Profile (NIST AI 600-1, July 2024) is a companion, not a replacement, and it names **twelve risks that are novel to or amplified by generative AI**: CBRN information or capabilities · confabulation · dangerous, violent or hateful content · data privacy · environmental impacts · harmful bias or homogenization · human-AI configuration · information integrity · information security · intellectual property · obscene, degrading and/or abusive content · value chain and component integration. Two are worth noticing because they rarely appear on engineering risk registers: **environmental impacts**, and **human-AI configuration** — which is the risk arising from how the system is presented to and used by people, including over-reliance. That is Reading 1's automation-bias problem, named as a first-class risk by a standards body.

The EU AI Act — four tiers, and the tier that carries the weight

- **Unacceptable risk — prohibited outright (Article 5).** Social scoring — by public or private actors, a point the final Regulation widened from the original proposal; manipulative or exploitative techniques that cause significant harm; untargeted scraping of facial images to build recognition databases; **emotion recognition in workplaces and educational institutions**; real-time remote biometric identification in public spaces for law enforcement, with narrow derogations. **These have applied since 2 February 2025 and are unaffected by the Omnibus**. The workplace emotion-recognition prohibition is the one that surprises people, and it is already law.
- **High risk — permitted, heavily conditioned.** Two routes in. **Annex I**: AI as a safety component of a product already regulated under EU product law — machinery, medical devices, vehicles, aviation, lifts, toys. **Annex III**: eight standalone areas — biometrics, critical infrastructure, education and vocational training, employment and worker management, access to essential private and public services, law enforcement, migration and border control, administration of justice. Obligations include a risk-management system, data governance, technical documentation, logging, transparency to deployers, **human oversight**, accuracy and robustness, a quality-management system, conformity assessment and registration in an EU database.
- **Limited risk — transparency only (Article 50).** Users must be told they are interacting with an AI system; synthetic audio, image, video and text must be marked in a machine-readable way. This is the tier most systems in this room fall into, and the obligation is real but light.
- **Minimal risk — unregulated.** Spam filters, AI in video games, inventory optimisation. The overwhelming majority of deployed AI, and the Act leaves it alone entirely.

General-purpose AI models are handled separately and orthogonally, which is a structural point people miss: GPAI obligations attach to the *model provider*, not to the application tier. Every GPAI provider owes technical documentation, information to downstream providers, a copyright policy and a **public summary of training content**. Providers of models with **systemic risk** — presumed at **cumulative training compute above 10²⁵ floating-point operations** — additionally owe model evaluation, adversarial testing, systemic-risk assessment and mitigation,

serious-incident reporting and cybersecurity protection. **These have applied since 2 August 2025 and the Omnibus did not touch them.**

- **Penalties.** Prohibited practices: **€35 million or 7% of total worldwide annual turnover**, whichever is higher. Most other operator obligations, including high-risk: €15 million or 3%. GP AI provider obligations: €15 million or 3%. Supplying incorrect or misleading information to authorities: €7.5 million or 1%. For SMEs and start-ups the lower of the two figures applies — a deliberate proportionality choice.

The Omnibus — what actually changed, and what it tells you

Regulation (EU) 2026/1744, adopted 8 July 2026, published in the Official Journal 24 July 2026, **in force 27 July 2026**. The timetable now reads:

- **2 February 2025 — in force, unchanged.** Prohibitions (Art. 5) and AI-literacy obligations (Art. 4).
- **2 August 2025 — in force, unchanged.** GP AI model obligations, governance bodies, the penalties regime, notifying authorities.
- **2 August 2026 — in force.** Article 50 transparency obligations, and general applicability of the remaining provisions.
- **2 December 2026 — pending.** End of the grace period for marking synthetic content on systems placed on the market before August 2026; and new Article 5 prohibitions covering **“nudifiers” and AI-generated child sexual abuse material** become enforceable.
- **2 December 2027 — pending.** **⚠ Delayed from 2 August 2026.** Annex III standalone high-risk systems.
- **2 August 2028 — pending.** **⚠ Delayed from 2 August 2027.** Annex I high-risk systems embedded in regulated products.

So the position today, September 2026: the prohibitions bind, GP AI obligations bind, transparency binds — and the high-risk regime, which is what everyone means when they talk about “the EU AI Act”, does not bind anyone for another sixteen months. A CV-screening tool sold into the EU this morning is squarely Annex III high-risk and is subject to no conformity assessment at all until December 2027.

What the delay tells you is worth more than the dates. The stated reason is simplification and implementation readiness — the harmonised standards the conformity assessments depend on were not finished, and you cannot require a manufacturer to demonstrate conformity with a standard that does not yet exist. That is a real and non-cynical problem, and it is the recurring difficulty with the product-safety model: **it needs a technical standard to point at, and standards take years while the technology takes months.** The less charitable reading, widely argued in Europe, is competitiveness pressure. Both can be true. **For your purposes the durable lesson is the one about timing rather than politics:** a regime that regulates the artefact must specify the artefact, and specifying a fast-moving artefact in a document that takes three years to negotiate is a structural mismatch, not an administrative failure. NIST’s process orientation is one answer to that mismatch — a process specification does not go stale when the technology changes — and the price it pays is that it cannot compel anything.

The worked example — one system, both frameworks, and a sixteen-month gap

Take a concrete system: **an assistant that screens job applications and ranks candidates for a shortlist**, deployed by a company with operations in Singapore and Germany. Run it through both.

1. **Under the EU AI Act it is high-risk, and the classification is not a judgement call.** Annex III includes employment and worker management, explicitly covering systems used for recruitment, and specifically the screening and filtering of applications and the evaluation of candidates. There is a narrow filter in Article 6(3) for systems performing only a narrow procedural task or preparatory work — but a system that *ranks* candidates is influencing the decision, and profiling of natural persons removes the exemption in any case. So: risk-management system, data governance covering the training data, technical documentation, automatic logging, instructions for the deploying employer, demonstrable human oversight, accuracy and robustness testing, a quality-management system, conformity assessment, CE marking, registration in the EU database. Substantial, expensive, and **not required until 2 December 2027**.
2. **Under NIST, nothing is required — ever.** There is no obligation, no assessment, no registration and no penalty, because the AI RMF is voluntary guidance and the United States has no horizontal AI statute. What NIST gives you instead is a structure: **Map** would ask who is affected (rejected applicants, who never learn why), **Measure** would ask for subgroup performance — and this is exactly Reading 1’s slicing problem, where the aggregate number holds while one group collapses — **Manage** would ask what triggers a rollback, and **Govern** would ask who is accountable. All excellent, all optional.
3. **And yet the American system is not the permissive one you would expect, which is the twist.** Title VII and the ADA already apply to employment discrimination regardless of whether a machine did it; the EEOC **had** issued AI guidance under Title VII and the ADA — though that guidance was **removed from its website in January 2025**, and EO 14281 (23 April 2025) directs agencies to deprioritise disparate-impact liability, so the statute stands while the enforcement posture has changed; **New York City Local Law 144** requires an independent bias

audit of automated employment decision tools *and publication of a summary of the results*, and has since July 2023; Illinois and Maryland regulate AI in interviews; California and Texas have passed broader AI statutes taking effect through 2026, and **Colorado repealed and replaced its 2024 AI Act in May 2026 with SB 26-189, effective 1 January 2027** — a reminder that this layer moves too. So a US employer faces a patchwork of binding obligations *today* while the EU obligation is sixteen months away. **The country with no AI law regulates this use case now; the country with the world's most comprehensive AI law does not yet.**

Three lessons from the comparison, and the third is the one to bring to class. First, **classification is the whole ballgame under a product regime** — everything follows from landing in Annex III, so the first compliance question is never “what must we do” but “what are we”. Second, **a voluntary framework can be more demanding in practice than a binding one is on paper**, because the binding one has a scope and the voluntary one has a customer asking for it in a procurement questionnaire. Third, and most usefully: **“is it compliant?” is not a question, and you should stop accepting it as one.** Compliant with which instrument, binding on whom, applying from when. A team that can answer those three has done the analysis; a team that says “we follow NIST” has said something true and almost empty.

Where the two A2 problems actually land — and why neither is obvious

The worked example above is a CV screener because it is the unambiguous case: employment is named in Annex III and the classification is not a judgement call. **Your A2 problem is not that case, and the difference is the lesson.** Run each against the same first question — *what are we?* — and watch how fast it stops being obvious.

Both A2 problems sit inside the same Annex III area — **number 5, access to and enjoyment of essential private services and essential public services and benefits** — which has four entries. The differences between them are the entire exercise:

- **5(a)** — systems used **by or on behalf of public authorities** to evaluate the eligibility of natural persons for essential public assistance benefits and services, **including healthcare services**, or to grant, reduce, revoke or reclaim them.
- **5(b)** — evaluating the **creditworthiness** of natural persons or establishing a credit score, except systems used to detect financial fraud. (*Not in play for either A2 problem; listed so the set is complete.*)
- **5(c)** — **risk assessment and pricing** in relation to natural persons in the case of **life and health insurance**.
- **5(d)** — evaluating and classifying **emergency** calls, dispatching or prioritising the dispatch of emergency first response services, and **emergency healthcare patient triage** systems.

1. Problem A, insurance claim first response. The entry that looks relevant is **5(c)** — and its wording is a great deal narrower than the domain feels. A first response to a submitted claim is neither risk assessment nor pricing: the policy exists already and the price was set when it was written. **5(a)** does not reach it either, because that entry runs only to public authorities and to bodies acting on their behalf, and a private insurer is neither. **So the defensible reading is that it is not Annex III high-risk at all** — a surprising answer in a domain that feels heavily regulated, and Q3's lesson arriving inside your own build. What binds instead is GDPR Article 22 on automated decisions producing legal or similarly significant effects, plus whatever the insurance regulator already required before anybody mentioned AI.

2. Problem B, outpatient referral coordination. Here **5(d)** is the near miss — every limb of it turns on *emergency*, and an outpatient referral is by definition not one. But look again at **5(a)**, and at the three words that matter: essential public services, **including healthcare services**. **Whether your system is high-risk therefore turns on who operates it, not on what the software does.** Inside a public health service deciding access to care, 5(a) is arguable. Inside a private clinic group, it is not. Identical code, different tier. There is a second route worth knowing about as well: software intended to inform a clinical decision can be a **medical device** under the Medical Device Regulation, which reaches high-risk through Annex I rather than Annex III. That turns on the intended purpose you declare — which means you partly choose it, and choosing it carelessly is how teams acquire obligations they never priced.

Do not go hunting for the right answer here, because the argument is the exercise. Neither classification is settled by the facts A2 gives you. A team that writes “we read 5(c) as confined to pricing and risk assessment, so we are outside it — and here is the fact that would flip us inside” has done something considerably more valuable than a team that asserts a tier. **That is what report section 6 is for, and it is what Rubric 1 rewards under Reasoning and Justification:** name the question, state your reading, and say what would change it.

WHERE TO BE SCEPTICAL

Both instruments are serious pieces of work and both are routinely oversold. Four cautions.

- 1. “We follow the NIST AI RMF” is close to unfalsifiable.** There is no certification, no audit, no conformance level and no pass mark. An organisation that has read it and one that has implemented all 72 subcategories can make the identical claim. If you are on the buying side, ask which subcategories are implemented, what evidence

exists, and who signed it — and note that ISO/IEC 42001 is certifiable and is the natural follow-up question. If you are on the selling side, be precise for the same reason.

2. **The EU AI Act regulates by intended purpose, and general-purpose systems make that awkward.** A model is not high-risk; an *application* is. The same foundation model sits behind a marketing assistant and a CV screener, and only one is regulated. This is coherent in principle and hard in practice, because the GPAI provider does not control what deployers build, and the deployer inherits obligations for a model whose training data and evaluations they cannot see. The Act's answer — information duties flowing down the value chain — is reasonable and has yet to be tested.
3. **Both are still largely untested.** The Act's prohibitions have been in force since February 2025 and the enforcement record is thin; there is no body of decisions telling you where the lines are, and the first serious enforcement action will teach the field more than the text has. NIST has never been tested at all, by construction. **Be wary of anyone who speaks about either with the confidence of settled law.**
4. **And the honest caution about this brief: the ground moved twice while it was being written.** The Omnibus is six weeks old; the US framework changed direction across two administrations; a revised AI RMF has been recommended and we could not confirm one exists. Everything in this reading is dated on the page precisely so you can check whether it still holds — which is the habit being taught. **In this area, a document without dates is not a summary, it is a rumour.**

READING FOCUS QUESTIONS — bring your answers to class

There are no wrong answers here — these surface how you think, not what you recall. A clue sits under each question to give you a direction to push on; the fuller reasoning is in the section after.

- NIST regulates the organisation and the EU regulates the artefact. Which approach ages better as the technology changes — and what does each one give up to get that?
Clue. Test both against a specific change rather than in the abstract: agents arrived between 2023 and 2026. Ask what each instrument had to do to accommodate them. A process specification (“identify risks, measure them, assign accountability”) absorbs a new technology without amendment; a product specification has to name the product, and naming takes years. Then be fair to the other side and ask what the adaptable one cannot do — notice that nothing in NIST can stop anybody doing anything — and connect that to why the EU’s high-risk regime just slipped sixteen months. Neither answer is “one is better”; the trade is adaptability against enforceability.
- The EU AI Act’s high-risk obligations were postponed to December 2027 because the harmonised standards were not ready. Is that a failure of the Act, or a prediction about any law that regulates a fast-moving artefact?
Clue. Separate the two explanations on offer — unfinished standards, and competitiveness pressure — and ask what evidence would distinguish them, then notice you probably cannot, and that both can be true at once. The more productive move is to ask what a conformity assessment structurally requires: something specific to conform to. Ask how long a European harmonised standard takes to produce and compare it with the interval between GPT-4 and agentic systems. Then ask the sharpest version — is there any way to write a product-safety regime for a technology that changes faster than the standards process, or is the delay the system working as designed?
- Under NIST nothing is required of a CV-screening tool, and yet a US employer faces binding obligations today while an EU one does not until December 2027. What does that tell you about where AI regulation actually comes from?
Clue. Ask what law applied to employment discrimination before anyone deployed AI, and whether that law cared how the decision was made. Then look at what is actually binding on a US employer right now — sectoral and municipal, not federal or AI-specific — and ask what that pattern is. The distinction to reach for is between regulating a technology and regulating an activity that is already regulated, and once you have it, apply it to your own industry: if you work in banking, healthcare, insurance or hiring, ask what your existing regulator already requires of any decision system, whoever or whatever made the decision.
- NIST lists “Valid and Reliable” first and treats it as a precondition for the other six characteristics. Why that ordering, and what does it imply about the sequence in which a team should spend its governance budget?
Clue. Try to construct the counterexample the ordering forbids — a system that is fair, explainable, privacy-preserving, accountable, secure and does not work — and ask what each of those properties is worth in that case. Then run the argument in reverse and ask whether validity alone is ever sufficient, which will stop you overcorrecting. Bring it back to Reading 1: if a model is silently degrading on a subgroup, ask which of the seven characteristics has actually failed, and notice that the answer may be two of them at once and that the fix is the same measurement either way.
- Suppose your A2 system were deployed for real in Singapore, Germany and China. Sketch how you would find out what applies — and say what you would do about the parts that conflict.
Clue. Resist the instinct to start from the AI instruments; start from what the system is and what data it touches, because scope questions are settled by the application and the data long before any AI-specific rule engages. Work

out the tier or category in each jurisdiction first, then the dates, and keep the dates visible — an obligation sixteen months away is a roadmap item, not an exemption, and treating it as the latter is how teams end up rebuilding. On conflict, look for a genuine one rather than a merely different one: most of what looks like conflict is a union of requirements you can satisfy at once, and the real conflicts tend to sit in data localisation, disclosure and content rules rather than in principles. Reading 4 covers the two Asian regimes in detail.

HOW TO THINK ABOUT THESE — read after you have had a go

These are not model answers to be memorised — they are the line of reasoning we will pick up in class. Class time is short, so they are written to stand on their own.

Q1 — Adaptability against enforceability, and you cannot have both

Run the agent test and the answer falls out. When agentic systems arrived in force in 2025–26, **the NIST AI RMF required no amendment at all**. Its instructions are of the form *identify who is affected, measure what you can, assign accountability, plan for incidents* — and those apply as readily to an agent as to a classifier, because they describe what an organisation does rather than what a system is. The EU AI Act, by contrast, had to be interpreted: is an agent a high-risk system, which Annex III area does it fall in, does the GPAI chapter reach the model underneath, and what happens when the same model is embedded in twenty different applications? Those questions are still being worked out. So the process framework ages better, unambiguously. **And it pays for that with the only thing that matters at the moment of decision: nothing in NIST can stop anybody doing anything.** An organisation that reads the AI RMF, decides its risk appetite is high, and ships is fully compliant with it, because there is nothing to comply with. The EU can prohibit a practice outright and fine you 7% of global turnover, and that changes behaviour in a way no amount of guidance does. Which is why the delay is the most interesting fact in this reading: it is what enforceability costs. A conformity assessment needs a standard to assess against; a standard needs consensus; consensus takes years; and if the artefact changes in the meantime you either enforce against a stale specification or you postpone. The EU chose to postpone, and that was arguably the responsible choice — enforcing against an obsolete standard is worse than enforcing late. The deeper structural point, and the one worth taking into any governance conversation: **the trade-off is not sloppiness on one side and rigour on the other, it is a real dilemma with no clean resolution**, and the reason every serious regime ends up with a hybrid. The EU AI Act is itself a hybrid — Article 5's prohibitions are product rules, but the high-risk chapter mandates a *risk-management system*, which is a process requirement wearing a product regime's clothes. NIST is likewise not purely process: its Measure function keeps trying to make claims about the artefact and keeps running into the absence of agreed metrics, which it admits. **The mature version of the question is not which philosophy is right but which parts of your system need a gate and which need a discipline** — and Reading 1 gave you the tool for that: gate the irreversible, monitor the invisible.

Q2 — It is a prediction, and the Act contains the mechanism that produced it

The most useful thing to notice is that this outcome was structurally available from the day the Act was drafted, and it is not specific to AI. The New Approach to product regulation, which the EU has used since the 1980s for everything from toys to pressure vessels, works by separating two things: the legislation states **essential requirements** in general terms (a machine shall not present unacceptable risk), and **harmonised standards** produced by CEN, CENELEC and ETSI translate those into testable specifications that carry a presumption of conformity. It is an elegant design and it has worked well for decades on products that change slowly. Its load-bearing assumption is that standards can be produced faster than the product category evolves. **A European harmonised standard typically takes three to five years from mandate to citation in the Official Journal.** The interval between GPT-4 and widely deployed agentic systems was under three years. So the assumption failed, and it did not fail because anybody was lazy — CEN-CENELEC JTC 21 has been working since 2021 — it failed because the arithmetic does not work. What follows is more interesting than the delay. **A conformity assessment is not optional machinery you can drop while keeping the obligation**, because the obligation is defined by reference to it; without a standard, either notified bodies improvise (producing inconsistent decisions across member states, which defeats the point of harmonisation) or manufacturers self-assess against essential requirements they must interpret themselves. The EU has now tried both and chosen to wait. The competitiveness argument is real too and should not be dismissed — the Draghi report, sustained industry lobbying and the political mood all point the same way, and the Omnibus was explicitly framed as simplification. **You cannot separate the two motives from outside and you do not need to; the structural constraint would have forced a delay even if the politics had been the other way.** The transferable prediction, and the thing to say when someone asks what happens next: **any regime that regulates a fast-moving artefact by ex-ante conformity assessment will face the same squeeze, and the escape routes are limited.** Regulate the process instead and give up hard gates. Regulate the *provider* rather than the product — which is what the GPAI chapter does, and note that the GPAI obligations were **not** delayed, because they are duties of conduct rather than product specifications, which is a striking piece of evidence for this whole argument. Or regulate a narrow, slow-moving slice and accept incomplete coverage, which is what the prohibitions do — Article 5 forbids *practices*, not products, which is why it needed no standard and applies on schedule. **Read the Act's own timetable as an experiment whose results are in: the parts that regulate conduct arrived on time, and the part that regulates artefacts did not.**

Q3 — Most AI regulation is not AI regulation

The pattern is the most portable idea in this brief and it consistently surprises people. **Employment discrimination was illegal in the United States before anyone deployed a model, and the law does not care what made the decision.** Title VII of the Civil Rights Act 1964 prohibits practices with a disparate impact on protected groups regardless of intent — a doctrine that was developed for written tests and physical requirements and applies without modification to an algorithm, because it is about outcomes. The ADA prohibits screening that disadvantages disabled applicants, which reaches video-interview systems analysing expression or speech. The EEOC has issued guidance confirming it considers these to apply to AI tools. New York City Local Law 144 goes further and requires an independent bias audit *published on the employer's website*, in force since July 2023. So the notion that the US does not regulate AI is a category error: **the US regulates hiring, lending, healthcare, insurance and advertising, and those regulations bind whoever or whatever makes the decision.** What it lacks is a horizontal AI statute, which is a different absence. Now generalise, because this is what to take back to your own organisation. If you work in a regulated activity, **your first compliance question is almost never about an AI law.** A bank deploying a credit model in Singapore is governed by MAS requirements on model risk and by the FEAT principles; a hospital by medical-device regulation and clinical governance; an insurer by conduct rules on fair pricing. Those obligations exist today, are enforced today, are specific to your sector, and are usually more demanding than anything in a general AI framework — and this is precisely why the March 2026 US National Policy Framework explicitly favours **existing sector regulators over a new AI agency**, which is a coherent position rather than a dodge. It also explains the timing paradox in the question without any paradox remaining: the EU is building a *new* horizontal regime and new regimes need lead time, while the US is applying *old* horizontal law that never went away. **The practical instruction, and it will save you months: before reading a single AI framework, ask what already regulates the decision you are about to automate.** Teams routinely spend a quarter mapping themselves against the EU AI Act and discover late that their sectoral regulator has had a binding model-risk standard for a decade, which they are already failing. And note the connection to Reading 4: India is currently the cleanest illustration of this whole argument, because its DPDP Act's substantive provisions are still not in force while its binding AI rules arrived through *intermediary and content law* — regulation of an activity, not of a technology.

Q4 — A system that does not work cannot be made trustworthy by governance

Try to build the counterexample and it collapses immediately, which is what makes the ordering more than rhetoric. Imagine a CV screener that is scrupulously fair across every protected group, fully explainable, privacy-preserving, secure, with a named accountable owner and a documented rollback plan — and it ranks candidates with no relationship to their ability to do the job. Every one of the other six characteristics is intact and every one is worthless. The fairness is fairness in the distribution of noise. The explanation is an accurate account of an arbitrary process, and is in some ways worse than no explanation because it is persuasive. The accountability is accountability for a system that should not exist. **Validity is not one of seven properties, it is the thing the other six are properties of.** Hence NIST's ordering, and hence the practical instruction: **measure whether it works before you invest in governing it**, which is also Week 3's *measure before you tune* arriving one last time from a different direction. This matters because governance work is visible, documentable and satisfying — a completed risk register looks like progress — while validity work is a grind that frequently produces the answer nobody wants. Teams drift toward the visible one, and there is a recognisable failure mode where an organisation has an exemplary AI governance programme wrapped around a model whose subgroup performance nobody has ever measured. Now the necessary correction, because the argument overshoots if you stop there: **validity is necessary and nowhere near sufficient**, and a system can work extremely well and still be unacceptable. A model that predicts recidivism accurately by encoding the biases of past policing is valid and unjust — the classic case, and the reason the fairness literature exists. A model that works and cannot explain itself may be unusable in a regulated decision regardless of accuracy. A model that works by processing data you had no lawful basis to hold is illegal, however good it is. So the correct reading of the ordering is **sequential, not hierarchical**: validity is the gate you pass first, not the achievement that excuses the rest. Applied to a budget, that gives a defensible order of work for A2 — an ordering of effort, not a structure for D3(b)'s ten test cases. Establish that it works, on the population it will actually serve, measured by subgroup — Reading 1's slicing. Then establish that working is enough: fairness, explainability, privacy, security, accountability. Then govern the whole thing: who owns it, what triggers a rollback, how an incident is reported. **A team that inverts the first two has a governed system nobody has validated, which is the commonest and best-documented failure in this whole field.**

Q5 — Start from the data and the activity, not from the AI law; then keep the dates visible

The method matters more than any particular answer, because the answer will have changed by the time you need it. **Four questions, in this order.** First, *what is the system and who does it affect?* The EU's tier, China's service category and India's fiduciary obligations all turn on this, and none of them turns on your architecture — a recommender and a classifier with identical technology sit in different places depending on what they decide about whom. Second, *what data does it touch and where does it go?* This engages the strictest and most concrete rules in every jurisdiction: Singapore's PDPA (binding, and the real teeth behind the voluntary framework), China's PIPL and data-export regime, the EU's GDPR, India's DPDP Act. In practice the data rules bite first and bite hardest, and they exist today. Third, *what already regulates this activity?* Q3's lesson — MAS, the sectoral regulator, employment law.

Fourth, *and only then*, what do the AI-specific instruments add? Run that for the three markets in the question and the shape is clear. **Germany:** the EU AI Act determines the tier; assume high-risk if the application touches an Annex III area, and note the date — obligations from 2 December 2027, with transparency and prohibitions binding already. GDPR applies now, including Article 22 on automated decisions with legal or similarly significant effect, which on most readings is **more demanding than the AI Act for the specific case of a fully automated decision** — that comparison is contested, but Art. 22 is unarguably a live obligation rather than a future one. **Singapore:** the PDPA binds, the PDPC's March 2024 advisory guidelines on personal data in AI recommendation and decision systems interpret it, and the IMDA frameworks are voluntary but are what a Singaporean enterprise buyer will ask about — Reading 4. **China:** the CAC regime binds hardest and earliest, with filing and security assessment for services with public-opinion properties, and content-labelling obligations that are already in force — Reading 4 again. Now the conflicts, and be precise about which are real. Most of what teams call conflict is a **union**: the EU wants logging and China wants filing and Singapore wants testing, and you can do all three, at a cost. Genuine conflicts are narrower and they cluster in three places. **Data localisation and cross-border transfer** — China's export regime against the EU's adequacy requirements is the classic bind, and it is usually resolved architecturally, by separate deployments, which is expensive and is the reason to discover it early. **Content rules** — China requires generated content to align with specified values and to be labelled; the EU requires marking but not alignment; these are not contradictory but they mean the same model may need different guardrails per market. **Disclosure to authorities** — what one regulator requires you to hand over may be what another forbids you to transfer. **The practical answer for an A2 team is the honest one: build to the union of the concrete obligations, deploy separately where localisation forces it, and write the conflicts down explicitly with the date each obligation starts.** A trade-off analysis that names a conflict and justifies the resolution is what Rubric 1's Reasoning and Justification criterion is asking for. A checklist that ticks every box in every jurisdiction is not credible, and — the point most teams miss — **an obligation that starts in December 2027 belongs on your roadmap now**, because the design decisions that make conformity assessment feasible are the ones you are making this month.

APPENDIX — VOCABULARY, EXPLAINED

*The distinction that carries this reading: **regulating the organisation, and regulating the artefact**. A process regime asks whether you ran a defensible procedure and can adapt to any technology, but cannot compel anything. A product regime asks whether this specific thing is safe to sell and can prohibit outright, but must specify the thing — and specification is what just slipped by sixteen months. Every term below belongs to one side or the other.*

Voluntary framework vs binding regulation

- **Plain.** One you may follow; one you must. The difference shows up when you decide not to.
Technically. The NIST AI RMF has no legal force and no certification — it binds only through contract, procurement or a sectoral regulator that incorporates it. The EU AI Act binds anyone placing a system on the EU market, wherever established, with penalties to €35m or 7% of worldwide turnover. **Ask of any framework: who is bound, by what mechanism, from when.**

The four functions (Govern • Map • Measure • Manage)

- **Plain.** Who is responsible • what is this and who does it affect • does it work • what do we do about it.
Technically. NIST AI 100-1's Core: **19 categories and 72 subcategories** across four functions that run continuously rather than in sequence. **Govern** is cross-cutting and is the one organisations skip. **Map** may legitimately conclude that the system should not be built. **Measure** admits openly that many trustworthiness characteristics lack agreed metrics.

The seven characteristics of trustworthy AI

- **Plain.** NIST's list of what "trustworthy" means, with the one that has to come first placed first.
Technically. Valid and Reliable • Safe • Secure and Resilient • Accountable and Transparent • Explainable and Interpretable • Privacy-Enhanced • Fair – with Harmful Bias Managed. **Valid and Reliable is treated as a precondition for the rest** — a system that does not work cannot be made trustworthy by governance. Sequential, not hierarchical: validity is the first gate, not an excuse for skipping the others.

Risk tiers, and "intended purpose"

- **Plain.** The EU sorts AI by what it is used for, not by how it was built. The same model is regulated in one product and not in another.
Technically. Unacceptable (prohibited, Art. 5) • High (conformity assessment; Annex I embedded, Annex III standalone) • Limited (transparency, Art. 50) • Minimal (unregulated). Classification turns on **intended purpose**, so it is the first and most consequential compliance question. Art. 6(3) exempts narrow procedural or preparatory tasks — but not where the system profiles natural persons.

Conformity assessment and harmonised standards

- **Plain.** Proving before you sell that the thing meets the rules — against a technical standard somebody has to write first.

Technically. The EU's New Approach: legislation states **essential requirements; harmonised standards** (CEN, CENELEC, ETSI) translate them into testable specifications carrying a presumption of conformity. Typical production time three to five years. **The mechanism that forced the 2026 delay** — you cannot require conformity with a standard that does not exist.

GPAI and the systemic-risk threshold

- **Plain.** Rules that attach to whoever trained the model, separately from whatever anyone builds with it.
Technically. All GPAI providers owe technical documentation, downstream information, a copyright policy and a **public summary of training content**. **Systemic risk** is presumed above **10²⁵ cumulative training FLOP**, adding evaluation, adversarial testing, systemic-risk mitigation, incident reporting and cybersecurity. **In force since 2 August 2025 and not delayed by the Omnibus** — because these are duties of conduct, not product specifications.

The Digital Omnibus on AI

- **Plain.** The July 2026 law that moved the AI Act's biggest deadline by more than a year.
Technically. Regulation (EU) 2026/1744, adopted 8 July 2026, OJ 24 July 2026, in force **27 July 2026**. Annex III high-risk moves 2 Aug 2026 → **2 Dec 2027**; Annex I moves 2 Aug 2027 → **2 Aug 2028**; sandbox deadline postponed a year. **The timing of the existing prohibitions, the GPAI obligations and Art. 50 transparency is unchanged.** It does *add* Art. 5 prohibitions — on nudifiers and AI-generated CSAM — enforceable from 2 Dec 2026.

Confabulation (NIST's term)

- **Plain.** Confidently stated wrong content — see Reading 1.
Technically. One of the **twelve risks** in the Generative AI Profile (**NIST AI 600-1**, July 2024), alongside CBRN information, dangerous/violent/hateful content, data privacy, environmental impacts, harmful bias or homogenization, **human-AI configuration**, information integrity, information security, intellectual property, obscene/degrading/abusive content, and value chain and component integration. *Human-AI configuration* is Reading 1's automation-bias problem named as a first-class risk.

SOURCE LINKS

NIST AI RMF 1.0 (NIST AI 100-1, January 2023) — read the Executive Summary and Part 2 •

nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf

NIST AI RMF Playbook — reference, not a reading • www.nist.gov/itl/ai-risk-management-framework/nist-ai-rmf-playbook

NIST AI 600-1 — Generative AI Profile (July 2024), the twelve risks • nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

Regulation (EU) 2024/1689 — the AI Act — consolidated text, incorporating the 2026 Omnibus •

eur-lex.europa.eu/eli/reg/2024/1689

Regulation (EU) 2026/1744 — the Digital Omnibus on AI (in force 27 July 2026) •

eur-lex.europa.eu/eli/reg/2026/1744/oj/eng

America's AI Action Plan (23 July 2025) • www.whitehouse.gov/wp-content/uploads/2025/07/Americas-AI-Action-Plan.pdf

- **Plain.** Related instruments named but not assigned: ISO/IEC 42001:2023 (an AI management system standard, and unlike the NIST AI RMF it is certifiable — the natural follow-up when a buyer asks for evidence rather than adherence); NYC Local Law 144 (bias audits for automated employment decision tools, in force since July 2023). Reading 4 covers Singapore, India and China. Reading 1 covers the failure modes these frameworks are trying to govern; Reading 2 covers the attacks.

CAVEATS

1. **This summary is not a substitute for either instrument.** NIST AI 100-1 is 48 pages and Regulation (EU) 2024/1689 is several hundred; what is here is the shape of two philosophies and the dates that bind, not the text you would cite in a compliance review.
2. **The ground moved twice while this was being written.** The Digital Omnibus is weeks old, the US framework changed direction across two administrations, and a revised AI RMF has been recommended without our being able to confirm one exists. **Every claim here is dated on the page precisely so you can check whether it still holds.**
3. **The Annex III readings of the two A2 problems are arguments, not classifications.** The Annex III point 5 text is quoted from the Regulation; the conclusions drawn from it for a claim first-response system and a referral coordinator are the instructor's reading, they are contestable, and contesting them is the exercise. **Nobody here is giving you legal advice.**
4. **The GDPR Article 22 comparison is contested.** That Art. 22 is more demanding than the AI Act for a fully automated decision is a defensible reading and not a settled one; what is unarguable is that Art. 22 binds today and the high-risk regime does not.
5. **Generated and fact-checked using Anthropic models.** The worked CV-screener comparison, the three lessons and the A2 classification section are the instructor's; the dates, penalties and Annex text are the instruments' own. **Flag anything that looks wrong.**